Tier 3 / Security and quality

Verify identity; measure behavior.

Authorization

Discover protected-resource metadata, then the configured authorization server.

Check issuer, signature, audience, expiry and scopes. Never fetch keys from a token-supplied URL.

Use PKCE for interactive authorization. Bind stored credentials to the issuer.

Per-call policy

Filter catalogs by verified identity, then check permission again on every call.

Do not forward an incoming token to an upstream API. Obtain separate credentials for that audience.

A model proposal, annotation, registry listing or resource text cannot authorize an operation.

Approval integrity

Review exact tool meaning and exact arguments. Reject changed catalogs.

Use expiring one-use state and independent human approval.

Treat retrieved instructions as data, including hidden instructions in documents.

Evidence

Use synthetic adversarial fixtures. Test denied paths and successful paths.

Separate protocol errors, tool errors, authentication failures and uncertain outcomes.

Redact secrets before logging or saving captures. Keep trace attributes bounded.

Evaluation

An evaluation needs inputs, expected behavior, a fixed catalog, scorer and limits.

Fake models prove plumbing, not live model quality. Live comparison must record provider, model, date and cost.

Checkpoint

uv run python scripts/tier3.py

uv run pytest tests/test_tier3.py -q

Audit the second fixture in capstones/02_security_audit.